Task 4

AWS Multi-AZ Network Fabric & IAM Least Privilege

Elevvo Pathways | Cloud & DevOps Engineering Internship

Prepared by: Dorcas Torshie Sai

Region: Europe (Stockholm), eu-north-1

Services: VPC, EC2, NAT gateway, IAM, S3, KMS, Secrets Manager

1. Overview

A secure two-Availability-Zone network was built in AWS. It has public subnets for a bastion host and private subnets for application servers. A private EC2 instance has no public address and reaches the internet only outbound through a NAT gateway. It uses an IAM role, with no access keys, to read one S3 bucket and one secret.

Requirement	What was built	Status
VPC across multiple AZs with public and private subnets	2 AZs, 2 public and 2 private subnets, internet gateway, route tables	Done
EC2 in a private subnet with no direct internet access, outbound through a NAT gateway	Private instance with no public IP; NAT gateway in a public subnet	Done
IAM role with least privilege, no hardcoded keys	Role task4-ec2-role; 3 actions on 3 specific resources	Done
Secrets read at runtime	Secret in Secrets Manager read through the role	Done
Bonus: default KMS encryption and no public access on S3	SSE-KMS default encryption; Block all public access on	Done

2. Architecture

```
                  Internet
                     |
            Internet gateway (task4-igw)
                     |
VPC task4-vpc  10.0.0.0/16
 |-- eu-north-1a
 |     |-- public subnet   10.0.0.0/20     bastion host, NAT gateway
 |     '-- private subnet  10.0.128.0/20   private app server (no public IP, IAM role)
 '-- eu-north-1b
       |-- public subnet   10.0.16.0/20
       '-- private subnet  10.0.144.0/20

Private route tables:  0.0.0.0/0 -> NAT gateway
Public route table:    0.0.0.0/0 -> internet gateway
```

Access path: laptop, then the bastion host (public IP), then the private server (10.0.x.x).

Term	Meaning
VPC	A private network inside AWS
Availability Zone	A separate data centre; using two removes a single point of failure
Public subnet	Has a route to the internet gateway
Private subnet	No route from the internet; outbound only through the NAT gateway
NAT gateway	A one-way door: private servers can go out, nobody can come in
IAM role	Temporary permissions that a server wears, so no access keys are stored
Least privilege	Only the actions and resources that are needed, with no wildcards

3. Safety Setup

Work was done as an IAM user, not the root user, in one region (Europe, Stockholm). A zero-spend budget was in place because the NAT gateway is billed by the hour. Every resource was named task4-... so that it could be found and deleted quickly.

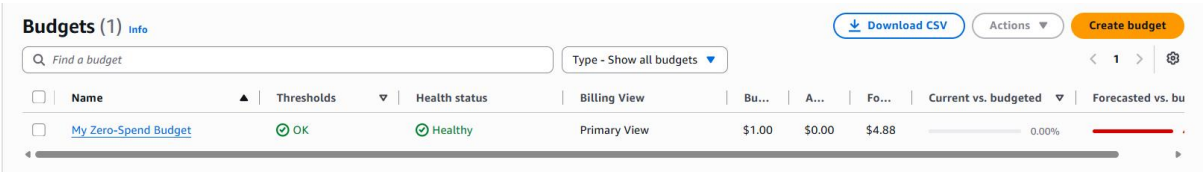


Figure 1: The zero-spend budget used as a cost guard.

4. Secure Storage (S3 and KMS)

The bucket task4-secure-bucket-10-11-26 was created with Block all public access turned on and default encryption set to SSE-KMS. A small test file was uploaded.

Why: Block Public Access means nobody on the internet can read the data, even if a wrong policy is added later. KMS encryption protects every object at rest, which is the bonus requirement.

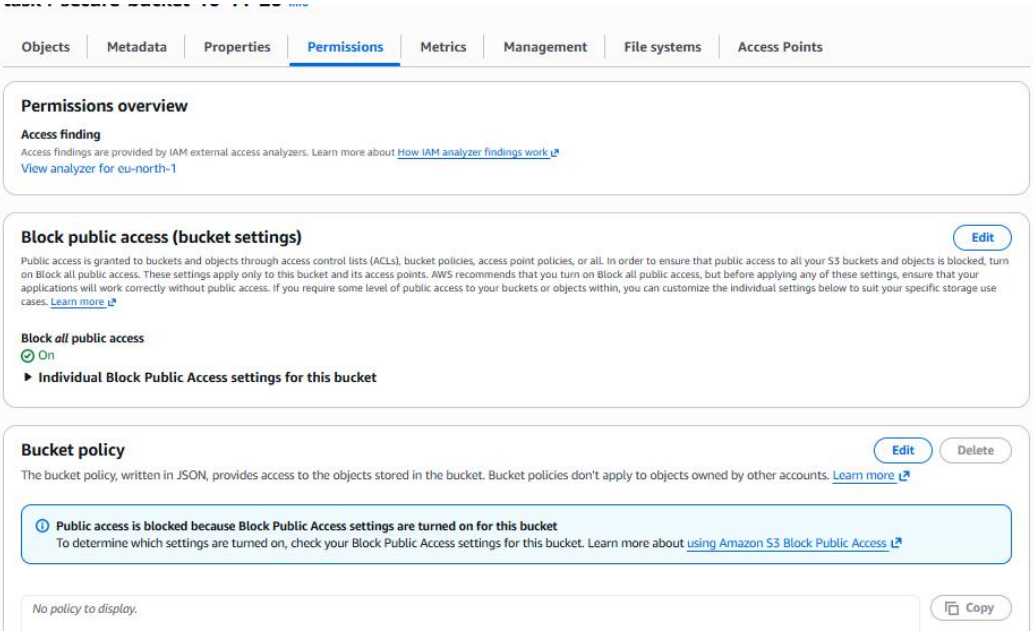


Figure 2: Block all public access is On, and no bucket policy exists.

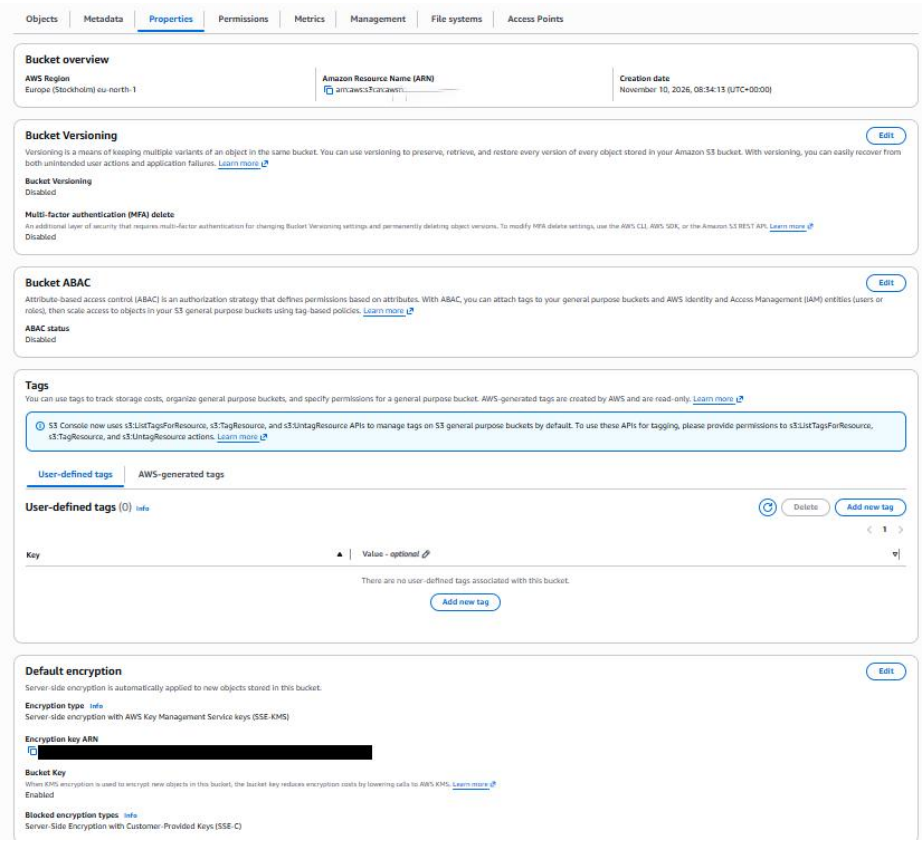


Figure 3: Default encryption is SSE-KMS.

5. Secret in Secrets Manager

The secret task4/app-secret holds a fake value (a db_password field), encrypted with the default Secrets Manager key. The slash in the name works like a folder.

Why: Applications fetch the secret at runtime, so no password is stored on the server. Only a server with the right role can read it.

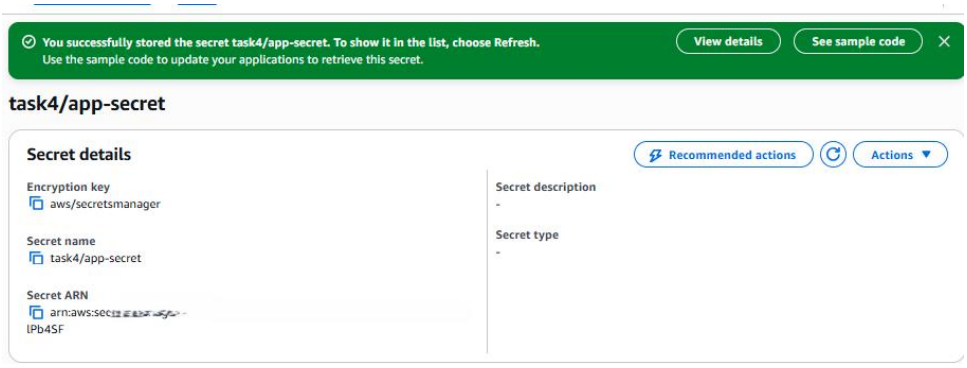


Figure 4: The secret, with its name, ARN and encryption key.

6. IAM Policy and Role

The policy task4-ec2-read-policy allows exactly three things. The account ID and secret suffix are shown as placeholders.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ReadObjectsFromOneBucket",
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::task4-secure-bucket-10-11-26/*"
    },
    {
      "Sid": "ListOneBucket",
      "Effect": "Allow",
      "Action": "s3:ListBucket",
      "Resource": "arn:aws:s3:::task4-secure-bucket-10-11-26"
    },
    {
      "Sid": "ReadOneSecret",
      "Effect": "Allow",
      "Action": "secretsmanager:GetSecretValue",
      "Resource": "arn:aws:secretsmanager:eu-north-1:<ACCOUNT_ID>:secret:task4/app-secret-
<SUFFIX>"
    }
  ]
}
```

- **s3:GetObject** applies to the files inside the bucket (the /* at the end).
- **s3:ListBucket** applies to the bucket itself. Objects and the bucket are separate resources, and mixing them up is a common mistake.
- **GetSecretValue** is limited to one secret ARN, not every secret.

The role task4-ec2-role was created with EC2 as the trusted entity and this policy attached.

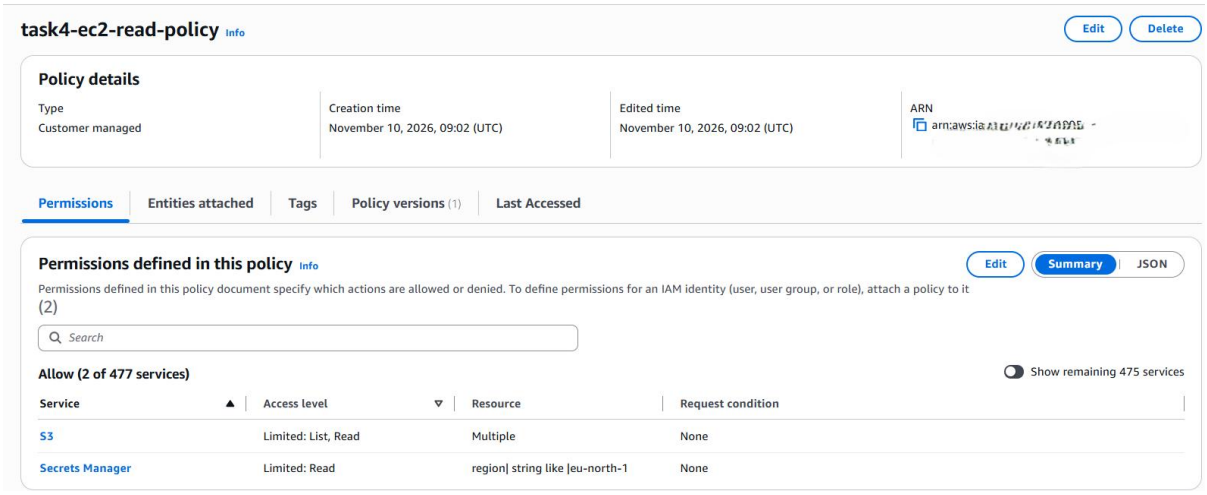


Figure 5: The customer-managed policy, with S3 and Secrets Manager access.

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Sid": "ReadObjectsFromOneBucket",
            "Effect": "Allow",
            "Action": "s3:GetObject",
            "Resource": "arn:aws:s3:::task4-secure-bucket-10-
11-26/*"
        },
        {
            "Sid": "ListOneBucket",
            "Effect": "Allow",
            "Action": "s3:ListBucket",
            "Resource": "arn:aws:s3:::task4-secure-bucket-10-
11-26"
        },
        {
            "Sid": "ReadOneSecret",
            "Effect": "Allow",
            "Action": "secretsmanager:GetSecretValue",
            "Resource": "arn:aws:secre
        }
    ]
}
```


Figure 6: The policy JSON: specific ARNs, no wildcards.

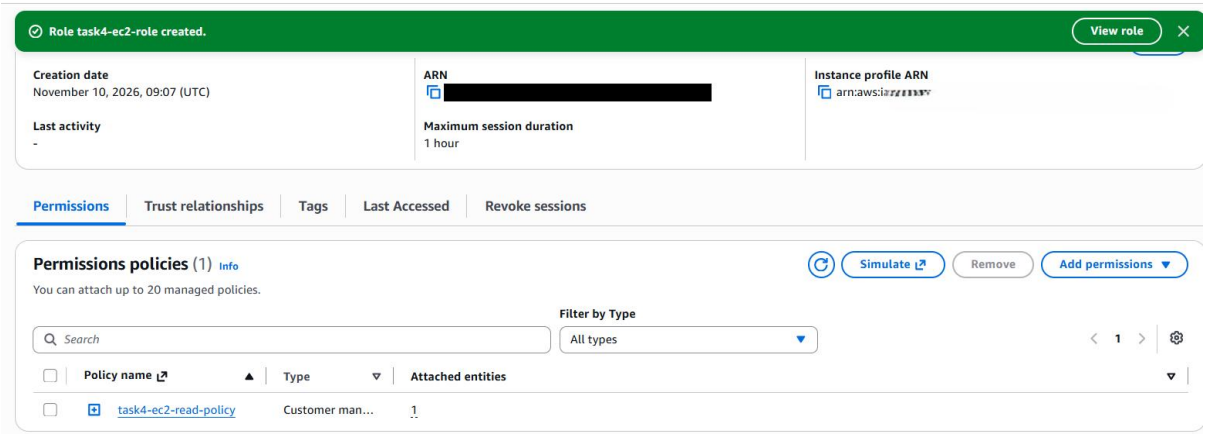


Figure 7: The role task4-ec2-role with the policy attached.

7. Network (VPC)

The VPC was created with the "VPC and more" option: CIDR 10.0.0.0/16, two Availability Zones, two public and two private subnets, one NAT gateway, and no VPC endpoints. Public subnets route 0.0.0.0/0 to the internet gateway, and private subnets route 0.0.0.0/0 to the NAT gateway.

Subnet	CIDR	Type and zone
task4-subnet-public1-eu-north-1a	10.0.0.0/20	Public, eu-north-1a
task4-subnet-public2-eu-north-1b	10.0.16.0/20	Public, eu-north-1b
task4-subnet-private1-eu-north-1a	10.0.128.0/20	Private, eu-north-1a

Subnet	CIDR	Type and zone
task4-subnet-private2-eu-north-1b	10.0.144.0/20	Private, eu-north-1b

A single NAT gateway was used to halve the cost. In production there would be one per Availability Zone.

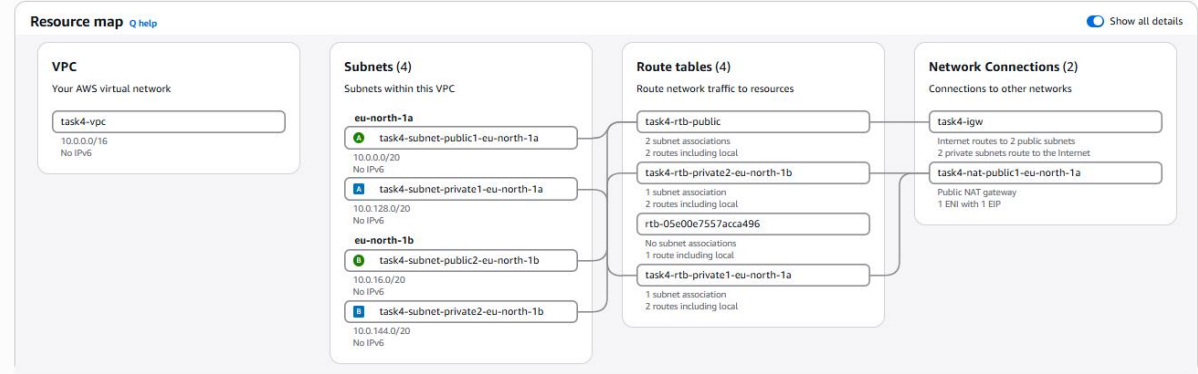


Figure 8: The VPC resource map: 4 subnets across 2 AZs, route tables, internet gateway and NAT gateway.

8. Security Groups and Servers

Security group	Inbound rule	Purpose
task4-bastion-sg	SSH (22) from my IP only	The only public entry point
task4-private-sg	SSH (22) from task4-bastion-sg only	The private server accepts logins only from the bastion

Outbound rules stay open so that the private server can reach S3 and Secrets Manager through the NAT gateway.

Instance	Placement	Details
task4-bastion	Public subnet, eu-north-1a	t3.micro, Amazon Linux 2023, public IP, no IAM role
task4-private-app	Private subnet, eu-north-1a	t3.micro, Amazon Linux 2023, no public IP, role task4-ec2-role attached



Figure 9: Both instances running; the private one has no public IPv4 address.

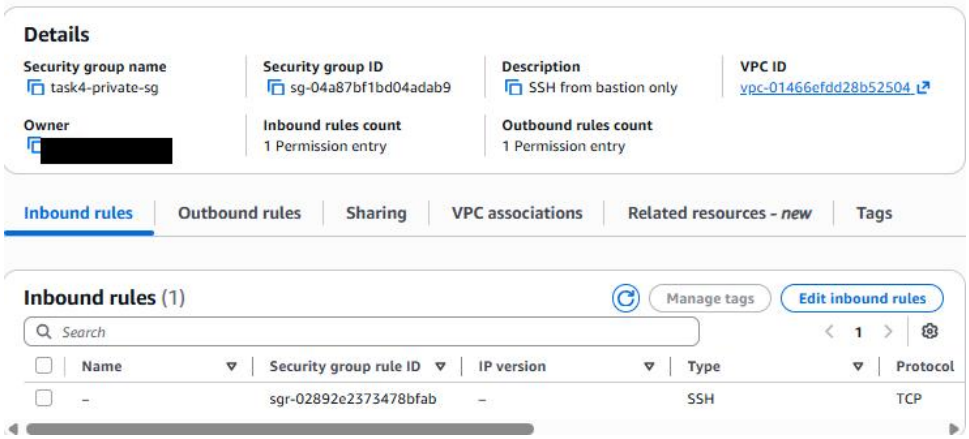


Figure 10: The private security group: "SSH from bastion only".

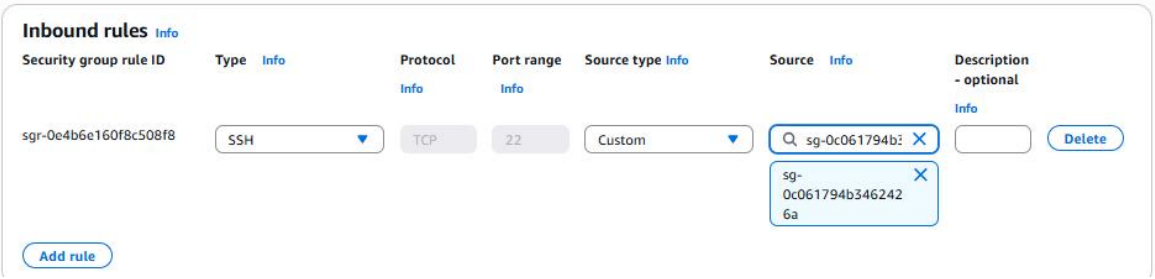


Figure 11: The inbound rule uses another security group as its source, not an IP address.

9. Access Through the Bastion

The private server has no public address, so it is reached by jumping through the bastion. From a Windows laptop, the key file permissions were fixed with icacls, the bastion was reached with ssh -i, and a small SSH config file was written so that one short command, ssh task4-private, goes through the bastion.

```
Host task4-bastion
    HostName <BASTION_PUBLIC_IP>
    User ec2-user
    IdentityFile ~/Downloads/task4-key.pem

Host task4-private
    HostName <PRIVATE_IP>
    User ec2-user
    IdentityFile ~/Downloads/task4-key.pem
    ProxyCommand C:/Windows/System32/OpenSSH/ssh.exe -W %h:%p task4-bastion
```



Figure 12: Key permissions fixed, then a successful login to the bastion.

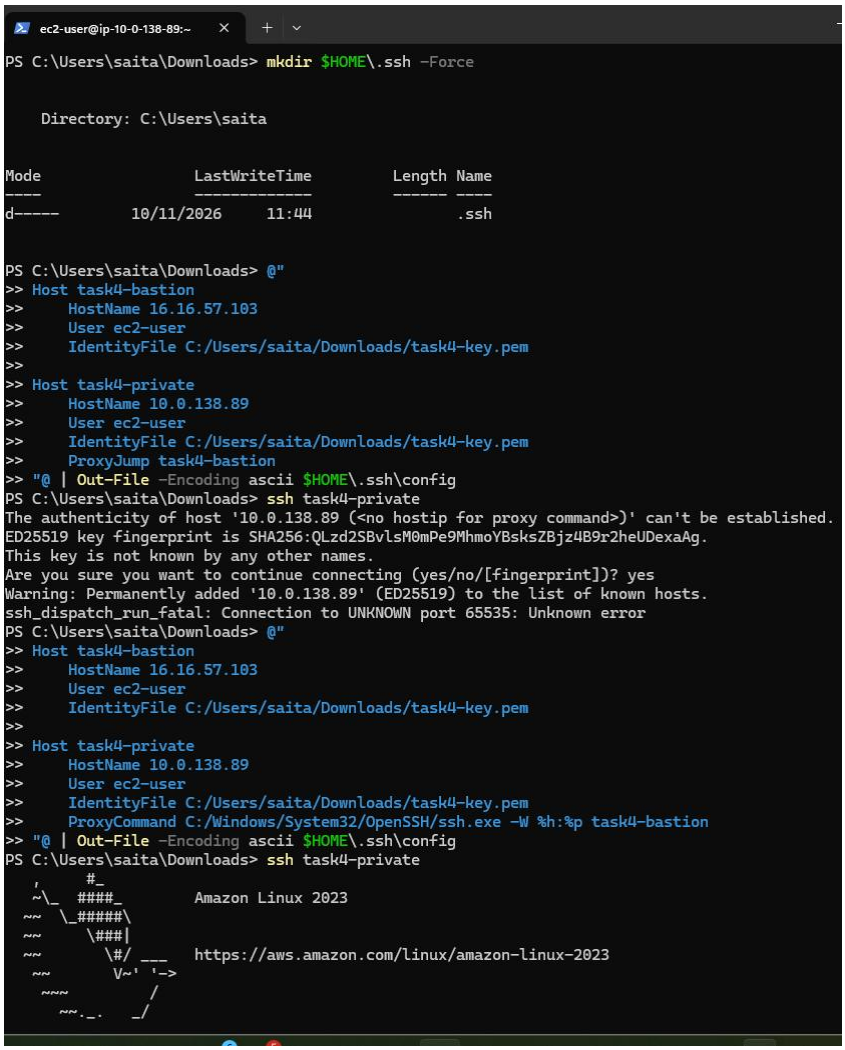


Figure 13: The SSH config, and a login to the private server through the bastion.

10. Verification

The following commands were run on the private server:

Check	Command	Result
Role in use, no keys	aws sts get-caller-identity	assumed-role/task4-ec2-role
Read the bucket	aws s3 ls s3://task4-secure-bucket-10-11-26	Lists the test file
Read the secret	aws secretsmanager get-secret-value --secret-id task4/app-secret --region eu-north-1	Returns the secret
Least privilege	aws s3 ls	AccessDenied
No stored credentials	ls ~/.aws/credentials	No such file or directory
Outbound through NAT	curl -sI https://aws.amazon.com | head -1	HTTP/2 200

The plain command aws s3 ls is denied on purpose. It needs permission to list all buckets, which the role does not have. That failure is the proof of least privilege, and listing the one allowed bucket works.

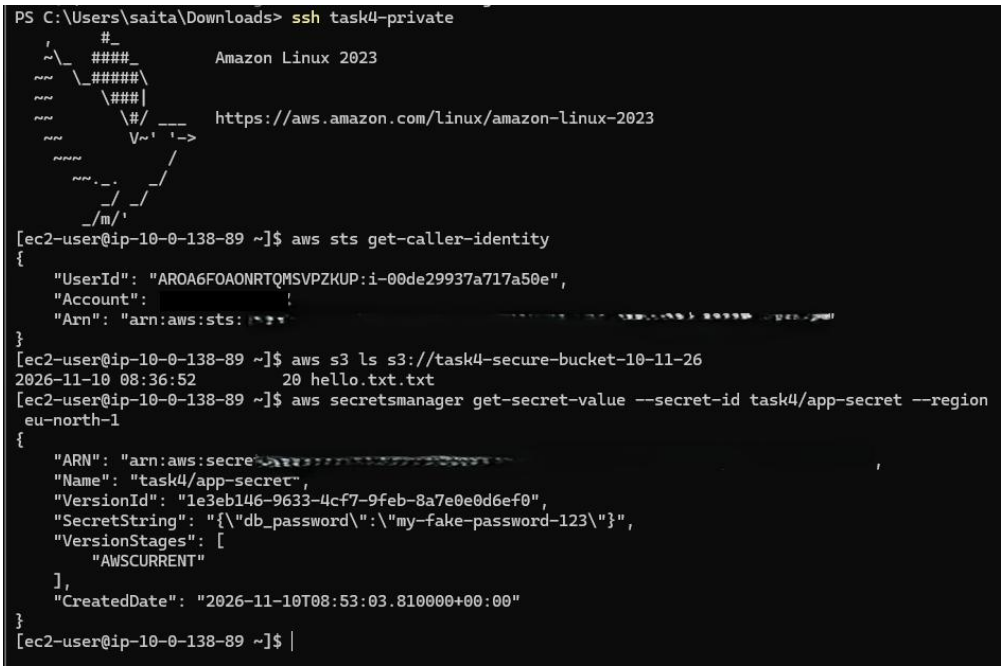


Figure 14: The role identity, the S3 listing and the secret value, with no access keys on the server.

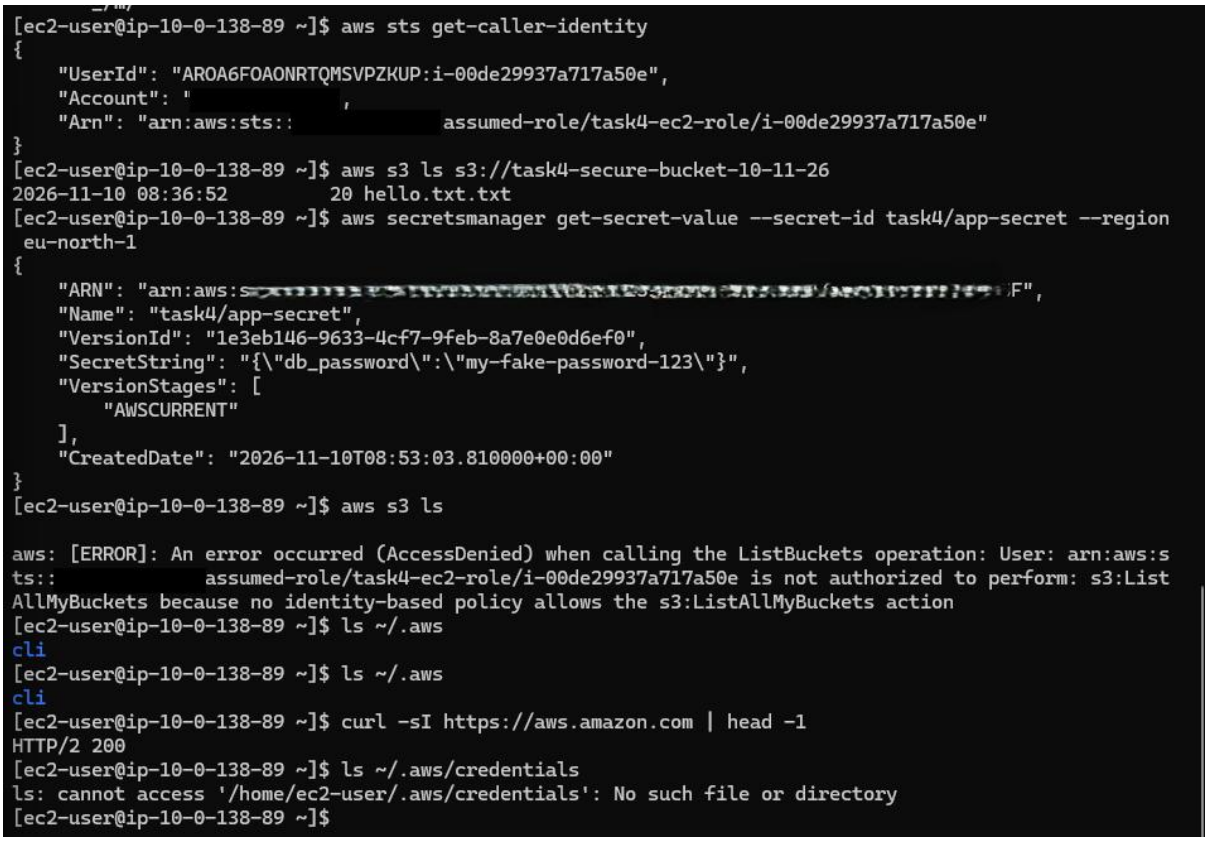


Figure 15: AccessDenied for listing all buckets, no credentials file, and outbound internet through the NAT gateway.

11. Cost Control and Cleanup

The NAT gateway and its Elastic IP are billed by the hour, so the lab was built, verified and deleted on the same day. Resources were removed in this order:

- Both EC2 instances terminated.
- NAT gateway deleted, then the Elastic IP released.
- VPC deleted, which removes its subnets, route tables, internet gateway and security groups.

- S3 bucket emptied and deleted.
- Secret scheduled for deletion.
- IAM role deleted, then the IAM policy.
- Key pair deleted, and the key file removed from the laptop.

12. Troubleshooting Log

Problem	Cause	Fix
Invalid parameter "/grant:r" in PowerShell	The command was split over two lines	Ran it as one line with icacls
Load key: Permission denied	The key file permissions were removed from my own user	Granted read access to my user and retried
Connection to UNKNOWN port 65535 with ProxyJump	Windows OpenSSH quirk	Used ProxyCommand with -W instead
aws s3 ls returned AccessDenied	Listing all buckets is not allowed by the policy	Expected; used the specific bucket path
~/.aws contains a cli folder	The AWS CLI keeps cache files there	Not credentials; confirmed there is no credentials file

13. What I Learned

- Why public and private subnets are separated, and how route tables decide what is reachable.
- How a NAT gateway gives private servers outbound access without exposing them.
- How IAM roles replace access keys, and how to write a policy with specific actions and ARNs.
- That an AccessDenied result can be proof that a security design is working.
- The habit of building, verifying and deleting cloud resources the same day to control cost.